The Report

1. Kịch bản

- Tìm hiểu threat report và đưa ra một số thông tin hữu ích nhằm cải thiện đội SOC

2. Thông tin từ báo cáo

- Cách thông kế
  - Kỹ thuật: đếm theo số lần xuất hiện
  - Threat: đếm theo số môi trường (khách hàng) độc lập bị ảnh hưởng
- Các threat phổ biến
  - Ransomware: bên cạnh mã hóa truyền thống, xuất hiện xu hướng mới
    - Mô hình affiliate (đối tác)
      - Nhiều affiliate tham gia các giai đoạn để giành quyền truy cập ban đầu
      - Affiliate dùng crimeware giành quyền truy cập và chuyển cho ransomware group

MALWARE FAMILY (PRECURSOR)	RANSOMWARE GROUP
Qbot	Egregor
Qbot	Sodinokibi/REvil
Qbot	Conti
Bazar	Conti
IcedID	Conti

    - Mới: đánh cắp data sau đó mã hóa → đòi tiền để data không bị công khai trên web đen
    - Giải pháp
      - Update, MFA cho đăng nhập RDP, phát hiện malware
      - Sao lưu giúp khôi phục nhanh nhưng không bảo vệ khỏi rò rỉ data

- Supply chain compromise: xâm nhập nhà phát triển phần mềm, sản xuất phần cứng, cung cấp dịch vụ → tấn công khách hàng
  - SolarWinds
    - Chiếm hạ tầng cập nhật → phát tán bản cập nhật có backdoor → backdoor liên lạc C2
  - Kaseya
    - Khai thác vul trong phần mềm VSA để triển khai ransomware (REvil)
  - NPM package compromises
    - NPM chứa thư viện cho dự án Node.js
    - Attacker chiếm quyền tác giả và phát hành các gói chứa mã độc
  - Log4j
    - Thư viện ghi log Java chứa vul Remote Code Execution (RCE)
    - Nhắm vào ứng dụng public-facing có lỗ hổng này
  - Giải pháp
    - Xây dựng danh mục phần cứng/mềm, dịch vụ đang tin cậy và phụ thuộc
    - Dùng Endpoint Detection and Response (EDR) + Network Detection → phát hiện hậu khai thác hoặc khi attacker đã xâm nhập vào mạng qua bên thứ 3
- Vulnerabilities
  - ProxyLogon **(CVE-2021-26855, CVE-2021-26857, CVE-2021-26858, CVE-2021-27065)**
    - Thực thi RCE trên Microsoft Exchange Server
    - Cài đặt web shell, thu thập data
    - Microsoft Exchange – Dịch vụ Mailbox Replication ghi file ASPX
      - Dấu hiệu cài web shell: msexchangemailboxreplication.exe ghi đè file ASP.NET (ASPX) xuống đĩa
      - Detection Analytic

```
process == msexchangemailboxreplication.exe
&&
```

```
filemod_extension == .aspx
```

- ProxyShell (CVE-2021-31207, CVE-2021-34523, CVE-2021-34473)
  - Thực thi RCE không cần xác thực
  - Mục đích: web shell, recon, di chuyển ngang, ransomware
  - Phát hiện: tương tự ProxyLogon
- PrintNightmare (CVE-2021-34527)
  - Leo thang đặc quyền hệ thống chạy dịch vụ Print Spooler cho phép thực thi mã với quyền SYSTEM cục bộ
  - Detection analytic: Print Spooler tạo shell

```
parent_process == spoolsv.exe
&&
process == cmd.exe
```

- Kaseya VSA (CVE-2021-30116)
  - Detection analytic: **certutil.exe giải mã nội dung**

```
process == certutil.exe
&&
command_line_includes (decode)
```

- ManageEngine products (CVE-2021-40539, CVE2021-44077, CVE-2021-44515)
  - Vul RCE trong 2 sản phẩm của Zoho ManageEngine
    - **ADSelfService Plus** (CVE-2021-40539)
    - **ServiceDesk Plus** (CVE-2021-44077)
  - Detection analytic: **ADSelfService Plus (CVE-2021-40539) dùng** Java **Keytool** để **di chuyển web shell**

```
parent_process == keytool.exe
&&
```

```
process == (cmd.exe || powershell.exe)
```

- Giải pháp
  - Dựa vào các Detection analytic đã cung cấp
- Affiliates
  - Chuyển hướng Software-as-a-Service – SaaS → affiliate là mối quan hệ nhà cung cấp - khách hàng của dịch vụ độc hại
  - Bao gồm
    - Phishing-as-a-Service (PhaaS)
    - Access-as-a-Service
    - Crypter-as-a-Service
    - Ransomware-as-a-Service (RaaS)
  - Giải pháp
    - Xác định mẫu hành vi ở từng giai đoạn để biết khi nào chuyển giao affiliate
- Crypters-as-a-service
  - Nhà phát triển bán hoặc cho affiliate thuê crypter để tấn công
  - HCrypt
    - Dùng để tránh cơ chế phát hiện, hỗ trợ tải payload (thường là RAT)
    - HCrypt thường dùng để giành initial access qua file phishing
  - Snip3
    - Né phát hiện và tải xuống mã độc bổ sung
    - Phân phối qua mail phishing, dụ tải file VBA và dùng lênh Powershell bị làm rối kết nối tới top4top[.]io
  - Detection opportunities
    - HCrypt và Snip3 sử dụng **cmdlet Invoke-Expression** để **thực thi nội dung PowerShell đã tải xuống theo kiểu fileless**, tức là **script không ghi xuống đĩa**.

```
process == powershell.exe
&&
```

```
parent_process == wscript.exe
&&
command_line_includes (iex || invoke || invoke-expression)
```

- Common web shells: duy trì truy cập + thực thi RCE
  - Vul ProxyShell của Microsoft Exchange dùng China Chopper web shell
    - Mở rộng và thực thi **ASP.NET, PHP, JSP** và các ngôn ngữ khác
    - Có xác thực mật khẩu → không triển khai thì nhiều kẻ thù có thể dùng web shell cùng lúc
  - Vul của Oracle WebLogic dùng Godzilla web shell
    - Hỗ trợ: ASP.NET, JSP, PHP
    - Xác thực: mật khẩu + khóa mã hóa → chỉ 1 kè thù có thể dùng web shell + mờ lưu lượng mạng tránh phân tích
  - Behinder web shell khai thác app Java
    - Load và thực thi payload đã biên dịch
    - Hỗ trợ mã hóa + ngẫu nhiên hóa User-Agent → khó phân tích
  - Giải pháp
    - Vá web
    - Chưa vá được thì: tạo IIS rewrite rules, vô hiệu Unified Messaging services, vô hiệu IIS application pools không dùng
    - Xem xét **file modification** và **process execution,**
      Exchange: kiểm tra **ASPX file lạ**
    - Web app khác: kiểm tra **worker process** spawn `cmd.exe`, `PowerShell`, `certutil` (Windows) hoặc `curl` (Linux)
  - Detection opportunities
    - Windows – IIS Worker process spawn certutil.exe

```
parent == w3wp.exe
&&
command_line_includes (certutil && -split)
```

    - Linux – PHP hoặc Java process spawn wget/curl

```
parent_process == (php || java)
&&
command_line_includes (wget || curl)
```

- User-initiated initial access: do user tải xuống file độc hại
  - **SocGholish, Yellow Cockatoo, Gootkit**: dùng user-initiated activity để truy cập ban đầu
  - **Rose Flamingo**: xâm nhập qua các trang web chia sẻ file giả mạo "miễn phí" hoặc "cracked software".
  - Các kỹ thuật phổ biến:
    - **SEO poisoning**: Adversary lợi dụng kết quả tìm kiếm để dẫn nạn nhân tới site độc hại.
    - **Drive-by downloads**: SocGholish nhúng trong site hợp pháp nhưng bị xâm nhập để yêu cầu tải về các update giả mạo.
    - Các file tải về thường **đặt tên giống nội dung người dùng tìm kiếm**, ví dụ: `this-is-my-query.exe`.
  - Giải pháp
    - Proxy chặn domain mới hoặc uy tín thấp
    - Ngăn tự chạy JS độc hại: thay đổi file **association mặc định** cho `.js` và `.jse`
- Malicious macOS installers
  - Người dùng thường có quyền admin → tải installer nguy hiểm → dính malware thường là malicious adware
  - Tác động: chạy ad, xâm phạm quyền riêng tư
  - Giải pháp
    - Update, antimalware tool
    - Chọn installer được **sign và notarized** bởi Apple.
- Remote monitoring and management abuse
  - RMM cho phép giám sát và điểm khiển máy từ xa qua kết nối an toàn và persistence → di chuyển data và điều khiển server
  - Giải pháp

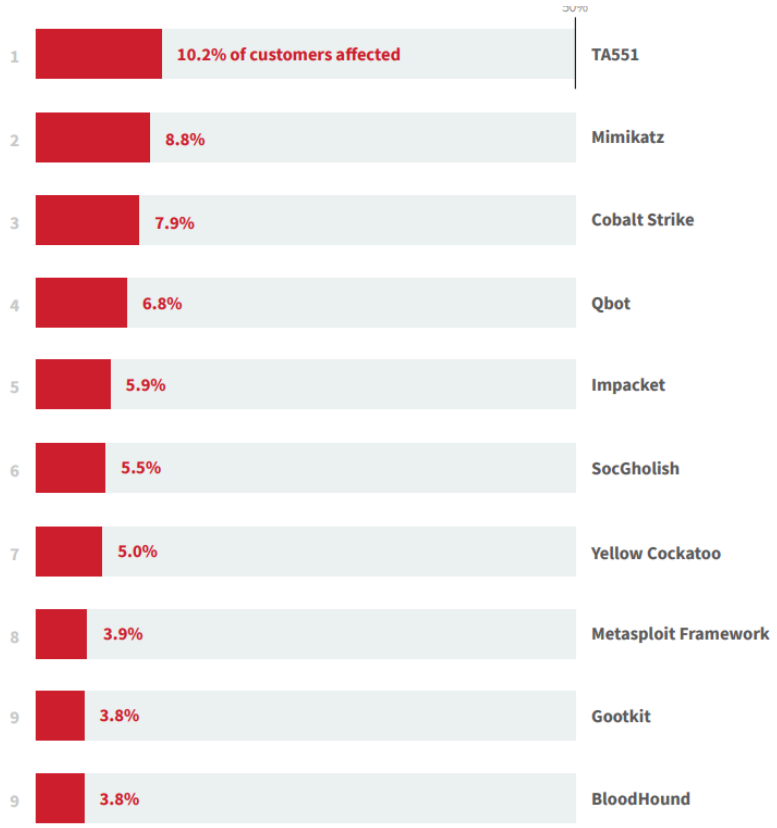
        - Theo dõi, xác nhận RMM hợp pháp
        - So sánh tiến trình đang chạy để tìm RMM bị lạm dung
    - Linux coinminers
        - Nhắm vào Linux, macOS dùng payload XMRig
        - Phương thức ban đầu:
            - SSH brute-force hoặc khai thác password yếu
            - Khai thác vul web app
            - Tải xuống script
        - Sau khi có quyền truy cập
            - Persistence:
                - Thêm public key vào `~/.ssh/authorized_keys`
                - Tạo task cho crontab
            - Defense evasion & competition: script loại bỏ coinminer
            - Payload XMRig (tến miến đổi) + pkill (dọn tiến trình cũ)
        - Giải pháp
            - Vá vul, MFA cho SSH, SSH chỉ xác thực qua key
        - Detection Analytics
            - Persistence – SSH authorized_keys

```
process == bash && filemod_filepath == .ssh/authorized_key
s
```

            - pkill chuẩn bị XMRig: process == pkill && command_line == xmr
            - **Renamed coinminers:** `command_line_includes (stratum
            - **Network connection tới mining pool:** `process != (chrome
    - Abusing remote procedure calls
        - PetitPotam
            - Chiếm phiên xác thực server để truy cập hệ thống nhạy cảm (AD CS)

        - Ép máy xác thực thông qua **NTLM relay** nhắm vào **Encrypting File System Remote Protocol (EFSRPC)**
        - EFSRPC: cho phép giao tiếp không xác thực
    - Ra mắt CVE-2021-36942 → yêu cầu phải xác thực hợp lệ trước khi tấn công
    - Giải pháp
        - Phát hiện
            - Event ID 4624: login ẩn danh hoặc đáng ngờ
            - Kết nối **named pipe** như `lsarpc` hoặc `efsrpc` tới Domain Controller (nhiều EDR có telemetry này)
        - Giảm thiểu
            - Vá DC khác phục CVE-2021-36942, vô hiệu hóa EFS
            - Bật **SMB signing** để ngăn NTLM relay.
            - Áp dụng **RPC filtering**, chỉ cho phép kết nối EFS đã xác thực qua **Kerberos**.
    - PrintNightmare - CVE-2021-34527: RCE và leo thang đặc quyền
        - Kết nối tới máy nạn nhân không cần xác thực và buộc tải DLL độc hại
        - Lạm dụng dịch vụ Print Spooler
        - Giải pháp
            - Phát hiện
                - Tạo DLL đáng ngờ: C:\Windows\System32\spool\drivers\(x64|W32X86)*.dll → giám sát DLL (không ký số)
                - Giám sát spoolsv.exe spawn process con
            - Ngắn chặn
                - Vá **CVE-2021-34527**.
                - Tắt **Print Spooler service** nếu không cần thiết.
                - Vô hiệu hóa **Point and Print**: reg add "HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows NT\Printers\PointAndPrint" /v Restricted /t REG_DWORD /d 0
- Defense validation and testing

        - Công cụ kiểm thử phổ biến
            - CrackMapExec: công cụ hậu khai tác để audit và đánh giá bảo mật AD
            - Phổ biến: Mimikatz, BloodHound, Impacket, Cobalt Strike và Metasploit
        - Giải pháp
            - Kiểm thử hành vi đơn lẻ + full chuỗi tấn công
            - Kiểm thử + Threat Intelligence
- Threats



    - Cobalt Strike: công cụ C2 duy trì persistence trong máy nạn nhân
        - Phân tích
            - Ransomware dùng để mở rộng và củng cố quyền kiểm soát
            - Chiến lược phát hiện
                - Giám sát **command-line**
                - Quét **hạ tầng mạng công khai**

    - Quét **in-memory**
    - Phân tích **binary động/tĩnh**
    - Phát hiện **chuỗi tiến trình (process lineage) bất thường**
    - Giám sát **lưu lượng mạng**
    - Thiết lập **baseline tần suất các lệnh reconnaissance**
  - Tài liệu
    - https://www.mandiant.com/resources/defining-cobalt-strike-components
    - https://blog.talosintelligence.com/2020/09/coverage-strikes-back-cobalt-strike-paper.html
    - https://thedfirreport.com/2021/08/29/cobalt-strike-a-defenders-guide/
    - https://thedfirreport.com/2022/01/24/cobalt-strike-a-defenders-guide-part-2/
    - https://go.recordedfuture.com/hubfs/reports/mtp-2021-0914.pdf
- Detection Opportunities
  - Dùng Cobalt Strike beacon gửi lệnh qua SMB dùng named pipe có thể cấu hình → phân tích sửa file liên quan name pipe đáng ngờ

```
file_modifications_include (
  pipe\msagent_ || pipe\interprocess_ || pipe\lsarpc_ ||
  pipe\samr_ || pipe\netlogon_ || pipe\wkssvc_ ||
  pipe\srvsvc_ || pipe\mojo_ || pipe\postex ||
  pipe\status_ || pipe\msse-
)
```

  - rundll32.exe chạy SQL Server Client Configuration Utility (cliconfg.exe) → **Cobalt Strike khai thác DLL Search Order Hijacking để bypass UAC**.

```
parent_process == rundll32.exe
&&
process == cliconfg.exe
```

  - Mẫu command-line khi leo thang đặc quyền bằng tính năng GetSystem

```
process == cmd
&&
command_line_includes (/(?i)echo\s+[0-9a-f]{11}\s+\>\;?\s+
\\\\\.\\
pipe\\[0-9a-f]{6}/.match)
```

- Impacket
  - Phân tích
    - Impacket: tập thư viện python scan vul, làm việc với giao thức mạng Win
    - Cho phép thực thi lệnh từ xa qua **SMB (Server Message Block)** và **WMI (Windows Management Instrumentation)**
    - Impacket cho phép
      - Trích xuất in4 xác thực dùng http://secretsdump.py/
      - Thực thi lệnh từ xa trong khi di chuyển ngang
      - Phát tán malware dùng http://smbexec.py/
    - Ứng phó
      - Cô lập endpoint → đánh giá có di chuyển ngang, đánh cắp in4 xác thực?
      - Nếu di chuyển ngang → cô lập các thiết bị đó
      - Đánh cắp in4 → reset password
        - Kerberos → reset 2 lần trong 10h
      - Sau đó: dừng process, xóa file, khôi phục cấu hình
  - Detection Opportunities
    - Phát hiện wmiexec thực thi lệnh cho phép shell bán tương tác thông qua WMI
      - Đặc điểm: output redirect về ADMIN$ share trên localhost, file output là Unix timestamp

```
parent_process == wmiprvse.exe
&&
process == cmd.exe
```

```
&&
command_line_includes (/(?i)cmd.exe \/Q \/c .*\\\\127.0.0.
1\\
ADMIN\$\\__[0-9]{1,10}\.[0-9]{1,10} 2>&1/)
```

- Thực thi lệnh dùng smbexec → shell bán tương tác qua SMB → outgh vào một file share dùng cho tương tác

```
parent_process == services.exe
&&
process == cmd.exe
&&
command_line_includes (/(?i)cmd.exe \/Q \/c echo cd \^>
\\\\127.0.0.1\\[a-zA-Z]{1,}\$\\__output 2\^>\^&1 > .* & /)
```

- SocGholish: kỹ thuật drive-by-download giả mạo bản update phần mềm lừa truy cập website độc
  - Phân tích
    - Threat giai đoạn initial access
    - Cách thức lây nhiễm (Drive-by-download)
      - Lừa user truy cập website tải file zip → chạy payload JS độc hại
      - File giả mạo bản update, Adobe Flash, Microsoft Teams
      - Sau khi chạy payload → kết nối C2 và có thể thả mã độc
    - Payload giai đoạn sau (Second-stage payloads)
      - Phát tán malware và thực hiện recon
    - Recon
      - Xác định endpoint nhiễm
      - Thông tin user login
      - Có thẻ enum domain hoặc khám phá domain
  - Detection Opportunities
    - Chạy script trong ZIP và sau đó kết nối mạng ra ngoài

```
process == wscript.exe
&&
command_line_includes ( .zip && .js )
&&
has_external_netconn
```

- Recon dùng whoami và ghi ra file temp cục bộ dạng rad<5-ký-tự-hex>.tmp

```
parent_process == wscript.exe
&&
process == cmd.exe
&&
command_line_includes ( whoami/all>> )
```

- Enum doamin dùng nltest.exe → bước đệm cho ransom

```
process == nltest.exe
&&
command_line_includes (/domain_trusts || /all_trusts)
```

- Yellow Cockatoo: cụm hoạt động liên quan Remote Access Trojan (RAT) triển khai không cần ghi file xuống đĩa (fileless), phân phối nhiều malware module
  - Phân tích
    - Sử dụng kỹ thuật đầu độc kết quả tìm kiếm, tồn tại bí mật trong môi trường bị xâm nhập
    - Xuất hiện trong cơ chế cài đặt ban đầu, persistence
    - Sau đó load và thực thi module bổ sung dạng fileless
    - Initial Access
      - Tìm kiếm → điều hướng web độc → tải file độc hại
    - Execution
      - Sau khi cài, file EXE hay MSI: tạo dòng lệnh, file TMP chạy powershell
      - Dẫn đến thực thi DLL độc hại: RAT viết dạng .NET assembly nạo vào powershell

- Defense Evasion
  - Hậu khai thác diễn ra trong memory
  - Né tránh: XOR hoặc base64, file chỉ cleartext trong memory sau khi loader kích hoạt
- Phòng thủ: web proxy chặn domain không đáng tin, ads

- Detection Opportunities
  - **PowerShell** để ghi **file LNK độc hại** vào thư mục Startup nhằm **duy trì persistence → khởi chạy script và cài DLL**

```
process == powershell.exe
&&
command_line_includes ( appdata )
&&
filemod_path_includes (start menu\programs\startup)
&&
filemod_extension == .lnk
```

  - PowerShell sử dụng **System.Reflection.Assembly** để load DLL vào bộ nhớ. (dễ dương tính giả)

```
process == powershell.exe
&&
command_line_includes ( reflection.assembly )
&&
command_line_regex_encoded == /(?i)::\(?load\)?(?:|file)\
(/
```

- Gootkit
  - Banking trojan: thêm payload, đánh cắp data, tồn tại bí mật
  - Phân tích
    - Tấn công đa giai đoạn, có loader viết bằng JS
    - Phát tán qua: mail, exploit kit cũ, web chứa payload độc
      - File ZIP (web) chứa JS độc hại
  - Detection Opportunities

- wscript.exe thực thi file JS trong %APPDATA%

```
process == wscript.exe
&&
file_path_includes ( %APPDATA% )
```

- PowerShell sử dụng dạng rút gọn của EncodedCommand → làm rối

```
process == powershell.exe
&&
command_line_includes == [any variation of the -encodedcom
mand switch]*
```

- BloodHound: quan sát + phân tích AD
  - Phân tích
    - Nó xác định đường tấn công và mối quan hệ đặc quyền trong AD → di chuyển ngang, leo thang,...
    - Nổi bật nhất là SharpHound: thu thập data
    - Để thu thập data, SharpHound kết nối nhiều host, nhiều port với nhiều named pipe; ban đầu giống SMB scan
  - Detection Opportunities
    - Một tiến trình kết nối lượng lớn port 445
    - Dòng lệnh đặc trưng

```
command_line_includes (
  -collectionMethod ||
  invoke-bloodhound ||
  get-bloodHo
)
```

- Rose Flamingo: đầu độc kết quả tìm kiếm lừa user
  - Phân tích
    - Cụm hoạt động vai trò initial access broker tập trung malware động cơ tài chính

- Nhắm nạn nhân dùng bản crack, thường dạng file nén (bên trong ≥ 2 file)
  - Một file **TXT "password"**
  - Một **archive được bảo vệ bằng mật khẩu**

- Detection Opportunities
  - File ZIP có TXT chứa chuỗi `password`

```
filemod_includes ( zip )
&&
filemod_includes ( password && txt )
```

  - Process có **schema đặt tên bất thường, t**rùng khớp với loader quan sát được trong các archive Rose Flamingo

```
process_name_includes (
  main- ||
  installer-v ||
  main_setup_x86x64 ||
  x86_x64_setup ||
  setup_x84_x64
)
```

  - File / path chứa các chuỗi thường gặp trong archive Rose Flamingo

```
filepath_includes (
  -free || -crack || -download || -key || -license || -iso
|| -Install
)
||
filename_includes (
  -free || -crack || -download || -key || -license || -iso
|| -Install
)
&&
filename_includes ( zip || 7z || rar )
```

- Silver Sparrow: cụm hoạt động trên macOS

- Phân tích
  - Phân phối thông qua **các file tải về từ AWS S3 bucket**
  - Cài đặt bằng **gói cài đặt macOS PKG**
  - **Phiên bản thứ nhất**
    - Chứa **Mach-O binary**
    - Chỉ biên dịch cho kiến trúc **Intel x86_64**
  - **Phiên bản thứ hai**
    - Chứa **Mach-O binary**
    - Hỗ trợ cả **Intel x86_64** và **Apple M1 ARM64**
  - Điểm độc đáo
    - Downloader
      - Sử dụng **JavaScript** để thực thi
      - Xuất hiện **binary biên dịch cho kiến trúc Apple M1 ARM64**, vốn còn rất mới vào thời điểm đó
    - Trong quá trình cài đặt, malware:
      - Thực thi **JavaScript commands**
      - Điều phối việc tạo **file và script** nhằm đảm bảo thực thi **liên tục (persistent execution)**
    - Các file này:
      - Định kỳ (mỗi **1 giờ**) cố gắng tải về một **payload trong tương lai**
      - Payload được xác định thông qua một file từ **một S3 bucket khác**
  - Có một file bất thường:
    - **._insu**
    - Dường như có chức năng **ra lệnh cho malware tự xóa khỏi endpoint**
- Detection Opportunities
  - PlistBuddy Thao tác **LaunchAgent plist và** Thiết lập **persistence**
    - Tham số: RunAtLoad

```
process == PlistBuddy
&&
command_line_includes ( RunAtLoad )
```

- Sqlite3 truy vấn cơ sở dữ liệu Quarantine → đánh giá nguồn tải file và báo về C2
  - File tải về lưu trong: ~/Library/Preferences/com.apple.LaunchServices.QuarantineEventsV*

```
process_name == ( sqlite3 )
&&
command_line_includes ( LSQuarantineURLString )
```

- Bazar: kích hoạt chiến dịch ransom
  - Gồm
    - BazarLoader: tải và triển khai payload tiếp theo
    - BazarBackdoor: duy trì truy cập, điều khiển hệ thống
  - Các affiliate tiêu biểu
    - TA551: phát tán mail độc
    - BazaCall: mail chứa sdt → dụ nạn nhân gọi → hướng dẫn từng bước cài malware
  - Chuỗi tấn công: Initial Access → Bazar → Cobalt Strike → Ransomware
  - Detection Opportunities
    - Microsoft Certificate Utility (certutil.exe) tải payload

```
process == certutil.exe
&&
command_line_includes ( urlcache )
```

- Latent threats
  - USB stowaways: dùng USB flash / USB thumb drive để tìm và lây nhiễm nạn nhân
    - Floxif

    - Malware lây nhiễm file, tự nhân bản
    - Nhiều biến thể của Floxif:
        - Ghi file DLL đi kèm là `symsrv.dll`
        - Vào một **đường dẫn duy nhất (unique location)**
    - Phát hiện: hành vi chỉnh sửa file
        - file_modification_includes (Common files / System / symsrv.dll)
- Gamarue
    - Biến thể phổ biến: **Autorun worm -** Lây lan chủ yếu qua **USB bị nhiễm mã độc**
    - Phát hiện: `explorer.exe` khởi chạy `rundll32.exe` không truyền DLL

```
process == rundll2.exe
&&
parent_process == explorer.exe
&&
command_line_does_not_include ( .dll )
```

- Conficker
    - Một loại sâu nằm giữa **USB worm** và **network worm khai thác vul NetBIOS – MS08-067**
    - Khi các biến thể tinh vi hơn được phát triển:
        - Chức năng **USB Autorun worm** cũng được tích hợp vào Conficker
        - Giúp nó tiếp tục lan truyền thông qua **sneakernet** (chia sẻ vật lý bằng USB)
    - Phát hiện
        - Chỉ tập trung vào các trường hợp:
            - `taskeng.exe` hoặc `svchost.exe`
            - Là tiến trình cha của `rundll32.exe`

```
process_name == rundll32.exe
&&
```

```
command_line == rundll32\.exe [a-z]{5,8}\.[a-z]
{1,3},[a-z]{5,8}
```

- Network worms
  - Khai thác vul phần mềm để lây nhiễm và giành quyền kiểm soát endpoint
  - Sau khi initial access
    - Lợi dụng kết nối mạng bị nhiễm → dò tài sản, lây nhiễm hệ thống mới,..
  - WannaCry ransomware
    - Biến thể ransom
      - Lây lan dưới dạng **SMB worm**
      - Khai thác lỗ hổng **ETERNALBLUE – MS17-010**
    - Phát hiện
      - Tên tiến trình có **tên trùng khớp với binary của WannaCry**

```
process_name == mssecsvc.exe
||
process_name == tasksche.exe
```

      - Local Security Authority Subsystem Service (lsass.exe) sinh ra tiến trình lạ (bị inj)

```
parent_process == lsass.exe
&&
process_name != werfault.exe || lsass.exe
```

  - WannaMine cryptominer
    - Nhắm vào triển khai payload đào tiền ảo (cryptomining)
    - Phát hiện : Detection analytic này xác định:
      - `powershell.exe` chạy với:
        - `nop` (NoProfile)
        - `noni` (NonInteractive)

```
process == powershell.exe
&&
command_line_includes ( -nop && -noni )
```

- Honorable mention
  - **Zloader**:
    - Không phải là **USB stowaway**
    - Cũng không phải **network worm**
    - Và thường không đủ "ồn ào" để lọt top các mối đe dọa

    Tuy nhiên, nó vẫn xứng đáng được nhắc tới như một **latent threat**.
  - Là banking trojan có thể phát tán ransom
  - Phát hiện
    - PowerShell phát lệnh: Thay đổi chính sách **loại trừ (exclusion)** của Windows Defender

```
process == powershell.exe
&&
command_line_includes ( Add-MpPreference || Set-MpPrefe
rence )
&&
command_line_includes ( ExclusionExtension || Exclusion
Path ||
ExclusionProcess )
```

- Techniques: các kỹ thuật MITRE ATT&CK phổ biến

NAME	TECHNIQUE RANK (SUB-TECHNIQUE RANK)	% OF CUSTOMERS AFFECTED
T1059: Command and Scripting Interpreter • T1059.001: PowerShell • T1059.003: Windows Command Shell	**1** (1) (2)	**53.4%** (35.0%) (28.1%)
T1218: Signed Binary Proxy Execution • T1218.011: Rundll32	**2** (3)	**34.8%** (23.3%)
T1047: Windows Management Instrumentation	**3**	**15.4%**
T1003: Credential Dumping • T1003.001: LSASS Memory	**4** (6)	**18.3%** (13.3%)
T1105: Ingress Tool Transfer	**5**	**20.4%**
T1055: Process Injection	**6**	**21.7%**
T1053: Scheduled Task/Job • T1053.005: Scheduled Task	**7** (4)	**14.7%** (12.2%)
T1027: Obfuscated Files or Information	**8**	**19.4%**
T1036: Masquerading • T1036.003: Rename System Utilities • T1036.005: Match Legitimate Name or Location	**9** (7) (11)	**22.1%** (15.6%) (7.9%)
T1574: Hijack Execution Flow • T1574.001: DLL Search Order Hijacking	**10** (5)	**8.4%** (7.8%)

-

3. Write-up

1. Name the supply chain attack related to Java logging library in the end of 2021 (Format: AttackNickname)

- Log4j:
  - Thư viện ghi log Java bị tấn công bởi vul RCE
  - Vul khai thác cho phần mềm đào tiền ảo và botnet

2. Mention the MITRE Technique ID which effected more than 50% of the customers (Format: TXXXX)

- T1059: Command and Scripting In terpreter
  - T1059.001: PowerShell
  - T1059.003: Windows Command Shell

3. Submit the names of 2 vulnerabilities belonging to Exchange Servers (Format: VulnNickname, VulnNickname)

- Gồm:
    - ProxyLogon và ProxyShell
    - Đều thực thi RCE trên Exchange Server

4. Submit the CVE of the zero day vulnerability of a driver which led to RCE and gain SYSTEM privileges (Format: CVE-XXXX-XXXXX)

- PrintNightmare (CVE-2021-34527) cho phép thực thi RCE với đặc quyền SYSTEM như ở cục bộ

5. Mention the 2 adversary groups that leverage SEO to gain initial access (Format: Group1, Group2)

- Gootkit và Yellow Cockatoo lợi dụng SEO
    - Thao túng kết quả tìm kiếm sang website độc hại
    - Tải xuống nội dung độc hại cải trang hợp pháp

6. In the detection rule, what should be mentioned as parent process if we are looking for execution of malicious js files [Hint: Not CMD] (Format: ParentProcessName.exe)

- wscript.exe
    - Thường dùng thực file tập lệnh như .vbs, .js

7. Ransomware gangs started using affiliate model to gain initial access. Name the precursors used by affiliates of Conti ransomware group (Format: Affiliate1, Affiliate2, Afilliate3)

- Các affiliates mà nhóm ransom Conti dùng để lấy init access: Qbot, Bazar, IcedID

8. The main target of coin miners was outdated software. Mention the 2 outdated software mentioned in the report (Format: Software1, Software2)

- 2 phần mềm lỗi thời: JBoss, WebLogic

9. Name the ransomware group which threatened to conduct DDoS if they didn't pay ransom (Format: GroupName)

- Fancy Lazarus: tống tiền nạn nhân bằng cách đe dọa se DDoS nếu họ không trả tiền

10. What is the security measure we need to enable for RDP connections in order to safeguard from ransomware attacks? (Format: XXX)

- MFA: xác thực đa yếu tố